

ShipShape Audit — Findings Summary

Phase 1 (Diagnosis) · branch shipshape/audit · generated 2026-05-19 · companion to AUDIT_REPORT.md

Condition of record (all baselines): documents=577, issues=328, sprints=35, users=31 (pnpm db:seed + seed-augment.sql, deterministic). Node v20.20.2 · PostgreSQL 16 (Docker) · macOS aarch64. Every number is produced by a committed re-runnable script in scripts/audit/ → raw in docs/audit/raw/. Phase-2 re-runs the same scripts for the before/after comparison.

Data-safety finding: pnpm --filter @ship/api test truncates ship_dev — running unit tests destroys seed data.

1 — Type Safety measured

TypeScript Compiler API AST walk (no linter exists in repo; strict mode ON). Scope A = non-test src.

Metric	Baseline
any / as / ! / @ts-ignore	94 / 433 / 325 / 0 = 852 total (25% target = 213)
By package	api-heavy (! 292), web-heavy (as 298), shared/ clean (0)
Top-dense files	weeks.ts (84) · projects.ts (51) · issues.ts (48) · UnifiedDocumentPage.tsx (37)

- 1. **High** — non-null ! (325, api 292) is the dominant risk class.
- 2. **High** — as assertions (433, web 298): downstream loss of discriminated-union narrowing.
- 3. **Medium** — explicit any (94) concentrated in api routes; **no linter** guards against new violations.
- 4. **Honesty correction** — orientation's regex undercounted ! ~100x; AST number supersedes it.

2 — Bundle Size measured

Production vite build --sourcemap + sourcemap byte attribution (no visualizer dep).

Metric	Baseline
Total bundle	2,275 KB raw / 695.5 KB gzip
Largest chunk	index-*.js — 2,025 KB raw / 575.7 KB gzip = 91.6% of all JS
Heaviest deps	emoji-picker-react (398 KB) · highlight.js (376 KB) · react-router (347 KB)

- 1. **High** — monolithic entry chunk (576 KB gzip, 91.6% of JS); no route/vendor splitting.
- 2. **High** — editor-only deps (highlight.js, emoji-picker) ship on first load; lazy-load = large low-risk win.
- 3. **Medium** — no manualChunks/vendor split (caching).
- 4. **Low** — candidate dead dep @tanstack/query-sync-storage-persister (verify).

3 — API Response Time measured

Dependency-free concurrent-load harness, API :3000 direct, warmup=10/budget=120/cell @ concurrency 10-25-50.

Endpoint (@conc 25)	P95
main page /api/documents?type=wiki (~300 KB)	201 ms (→ 362 ms @50)
list issues /api/issues (~280 KB, 328 rows)	124 ms (→ 222 ms @50)
weeks · search · view-document	≤ 25 ms (genuinely fast)

- 1. **High** — two unbounded list endpoints dominate & degrade ~linearly with load; SQL is <1.5 ms so cost = serializing 300/280 KB JSON on the shared event loop. Pagination = target.
- 2. **Medium** — global rate limiter **100 req/min in prod** — very low for a collaborative multi-user app.
- 3. **Medium** — per-request session write adds a DB round-trip to every endpoint's latency floor.

4 — Database Query Efficiency measured

Postgres full statement logging; 5 marker-bracketed flows, API-pool PIDs only.

Flow	Queries / slowest / N+1
main page / view doc / issues / weeks / search	4–5 queries · <1.5 ms slowest · no N+1

1. **High** — universal auth tax: every flow runs `SELECT sessions + UPDATE sessions.last_activity` — 2 of every 4–5 queries are auth overhead. Throttling the write = ~25% queries on a flow.
2. **Medium** — no pagination/`LIMIT`; result sets grow linearly with workspace size (hidden at 577, visible at 10×).
3. **Low** — well-indexed, no slow query today; gains come from query *count*, not speed.

5 — Test Coverage & Quality measured

Unit run 3× for flakiness; E2E static catalog; coverage attempted.

Metric	Baseline
Unit (api)	451 / 451 pass , 0 flaky over 3 runs, ~16 s — healthy
E2E	~882 tests / 71 specs — not runnable by sanctioned method
Coverage %	Unmeasurable as-shipped (api: @vitest/coverage-v8 not installed; web: no config)

1. **High** — the mandated `/e2e-test-runner` skill **does not exist** in the repo; the only sanctioned way to run the 882-test suite is unimplemented.
2. **High** — coverage unmeasurable as-shipped (tooling absent).
3. **Medium** — `pnpm test` runs only api unit; 16 web unit files silently excluded. Doc undercount (~10×).
4. **Positive** — the unit layer itself is stable & fast.

6 — Runtime Errors & Edge Cases measured

Reproducible Playwright harness: console scan · malformed input · RT1 collab durability (validated instrument + online control + API-verified) · slow-3G · PG error-log scan.

Probe	Result
Normal use (6 pages)	0 console/page/network/5xx errors — clean
Bad UUID path param	500 + raw Postgres error (unvalidated → DB error)
Bad JSON / missing CSRF	HTML stack-trace pages (info leak, inconsistent contract)
Wrong Content-Type body	201 — silently creates a default doc
RT1 collab durability	PERSISTED — offline path robust (y-indexeddb + replay)

1. **High** — unvalidated path params surface raw DB errors as HTTP 500 (+ minor info disclosure).
2. **High** — error responses leak stack traces as HTML; inconsistent error contract API-wide.
3. **Medium** — no Content-Type enforcement → silent junk-document creation.
4. **Medium / honest correction** — RT1 **empirically downgraded**: client offline path is robust; residual risk narrowed to server-side swallowed persist failure only.
5. **Medium** — slow-3G first load ≈ 4.9 s (bundle-bound; corroborates Cat 2). No centralized API error logging (observability gap).

7 — Accessibility

measured

axe-core WCAG 2.1 A+AA + keyboard/contrast/landmark harness across the same 6 pages. Instrument validated by an unauthenticated **login control** (0 violations, 4/4 keyboard).

Probe	Result
axe Critical / Serious	2 / 17 node instances; 3 rules: aria-required-children, listitem, color-contrast
Keyboard nav (authenticated)	Broken — only 3 distinct focusable in 60 Tabs vs 4/4 control, despite 369–1017 interactive els
Color contrast	15 AA failures on /my-week (low-opacity muted text)
README "508 / WCAG-AA" claim	CONTRADICTED by the evidence above

1. **High** — keyboard navigation broken on the authenticated app (WCAG 2.1.1/2.4.3, core 508).
2. **High** — README's Section 508 / WCAG 2.1 AA compliance claim is false as shipped (compliance overclaim on a .treasury.gov target).
3. **Medium** — 15 color-contrast AA failures; critical aria-required-children + listitem structure bugs.
4. **Positive** — solid baseline hygiene (lang/title/h1/landmarks, 20–23 axe passes/page); failures are localized.

Three strongest Phase-2 candidates (map to the deck's measurable $\geq 20\%$ targets, each independently reproducible & low-blast-radius): **(1)** paginate the two heavy list endpoints $\rightarrow$ P95 drop on ≥ 2 endpoints (`cat3-api.mjs`). **(2)** throttle the per-request `last_activity` write $\rightarrow$ fewer queries on ≥ 1 flow (`cat4-db.mjs`). **(3)** code-split + lazy-load editor-only deps $\rightarrow$ smaller initial bundle (`cat2-bundle.mjs`).

Phase-1 gate: **7 / 7 categories baselined**. Full methodology, raw evidence, and the cross-category ranked findings summary (High/Medium/Low + reproduction) live in `AUDIT_REPORT.md`. No application code was changed during the audit — only reproducible measurement instruments and deterministic test data.